IT biztonság jegyzet

1 Bevezetés az IT-Biztonságba

1.1 Az IT-biztonság célja, főbb fogalmai, összefüggései

Az élet minden területén hálózatokba szervezett számítógépes rendszereket használunk, melyek óriási mennyiségű adatot generálnak, tárolnak, továbbítanak, és dolgoznak fel, valamint különböző szolgáltatások ezreit nyújtják számunkra. Az ilyen rendszereket a továbbiakban IT-rendszereknek nevezzük, ahol az IT rövidítés az *információs technológiák* kifejezésre utal. Nyugodtan kijelenthetjük, hogy az életet nagyon nehezen tudnánk már elképzelni IT-rendszerek nélkül, azaz a tőlük való függésünk kritikus mértékű.

Ebben a kontextusban nagyon fontos követelmény az IT-rendszerek megbízható működése. A megbízhatóság alatt két dolgot is érthetünk: (1) ellenállást a véletlen hibák és a természeti katasztrófák okozta károkkal szemben, vagy (2) ellenállást a szándékos támadásokkal szemben.

Az IT-biztonság az IT-rendszerek második értelemben vett megbízhatóságával foglalkozik, azaz az IT-biztonság célja annak elérése, hogy IT-rendszereink megbízhatóan működjenek még abban az esetben is, ha éppen szándékos támadás alatt állnak, azaz egy intelligens entitás kifejezetten rossz szándékkal próbálja a működésüket befolyásolni, ellehetetleníteni.

Az angol terminológiában az első értelemben vett megbízhatóságot *reliablity*-nek nevezik, a második értelemben vett megbízhatóságot pedig *trustworthiness*-nek. Így az angol szakirodalomban általában egyértelmű, hogy éppen melyik fajta megbízhatóságról van szó. A magyar nyelvben nincsen erre két szavunk, ezért mindig fontos tisztázni, hogy melyikről beszélünk éppen.

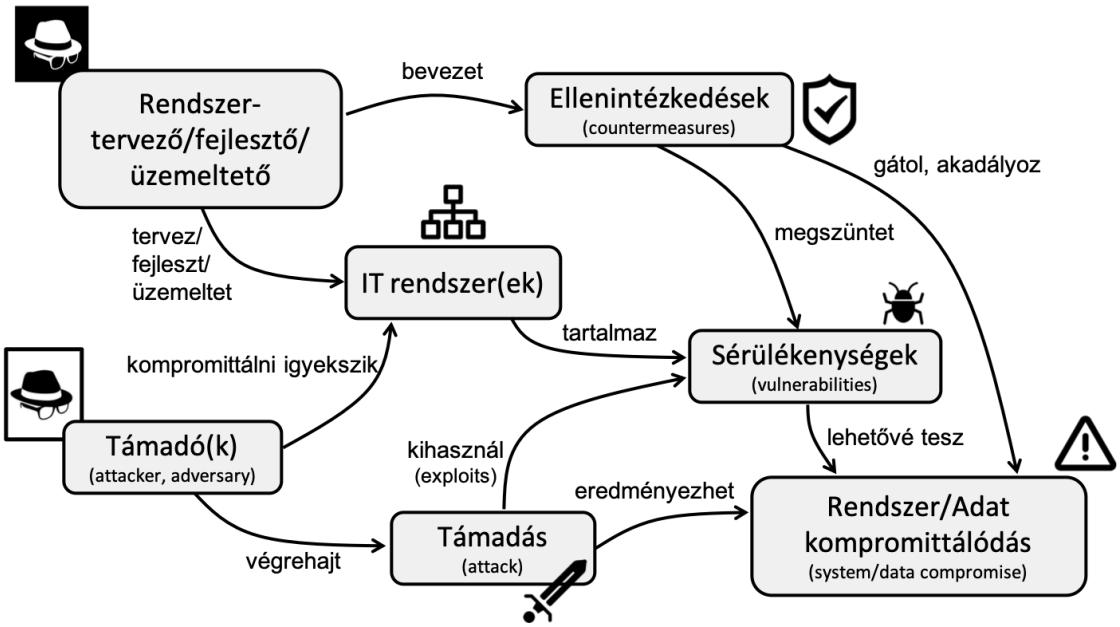
Természetesen a véletlen hibákból és természeti katasztrófákból származó károk elkerülése, enyhítése is fontos feladat. Ezt a követelményt a rendszerek hibatűrő tervezésével és kialakításával lehet kielégíteni. Fontos azonban megérteni, hogy azok a módszerek, amelyekkel egy IT-rendszer hibatűrővé tehető (például redundáns adattárolás vagy adatátvitel hibajavító kódolással), általában nem elegendőek az IT-biztonság eléréséhez. Azaz, szándékos támadások ellen általában nehezebb védekezni, mint véletlen hibák ellen. Az IT-biztonság e nehezebb feladat megoldását célozza meg.

Az IT-biztonság problémakörének főbb fogalmait és a fogalmak között fennálló összefüggéseket egy "drámai" hasonlattal lehet szemléletesen bevezetni. Minden jó drámában van egy pozitív és egy negatív szereplő, és közöttük fennáll egy alapkonfliktus, amely körül a cselekmény bonyolódik. Az IT-biztonság "drámájában" a pozitív hős a rendszertervező/-fejlesztő/-üzemeltető, aki IT-rendszereket tervez/fejleszt/üzemeltet. A "dráma" negatív szereplője a *támadó* (attacker). A közöttük fennálló alapkonfliktus lényege, hogy a támadó az IT-rendszereket kompromittálni igyekszik, míg a rendszertervező/-fejlesztő/-üzemeltető próbálja az IT-rendszerek kompromittálódását elkerülni, megakadályozni. Később részletesen is szó lesz arról, hogy mit értünk egy rendszer kompromittálódása alatt, most elegendő erre úgy gondolni, hogy egy rendszert akkor tekintünk kompromittáltnak, ha a tervező/fejlesztő/üzemeltető által nem kívánt állapotba került. A kompromittált állapot bekövetkezése, huzamosabb ideig történő fennállása a tervező/fejlesztő/üzemeltető számára általában valamilyen kárt okoz, míg a támadó ebből általában valamilyen hasznot húz.

A támadó a rendszer kompromittálását támadások végrehajtásával próbálja elérni. A *támadás* (attack) egy - többnyire komplex - folyamat, melynek végrehajtása során a támadó a rendszer *sérülékenységeit* (vulnerability) *használja ki* (exploit) a támadási cél elérése érdekében. Látni fogjuk majd, hogy az IT-rendszerek mindig tartalmaznak sérülékenységeket, gyenge pontokat, amelyeket a támadó megpróbálhat kihasználni, és kiderül majd az is, hogy mi ennek az oka. A támadások elleni válaszként a rendszertervező/-fejlesztő/-üzemeltető *biztonsági mechanizmusokat* (security mechanism), *ellenintézkedéseket* (countermeasure) vezet be, amelyek célja a rendszer védelme a támadásokkal szemben, azaz a támadó dolgának

megnehezítése. A későbbiekben részletesen tárgyaljuk majd, hogy milyen biztonsági mechanizmusok, védelmi módszerek állnak a rendszertervező/-fejlesztő/-üzemeltető rendelkezésére, és hogy hogyan lehet az ellenintézkedések gazdag tárházából kiválasztani az alkalmas megoldást.

A fentieket szemlélteti az 1. ábra, melyen a westernfilmekhez hasonlóan a pozitív szerepet játszó rendszertervezőt/-fejlesztőt/-üzemeltetőt fehér kalapos szereplőként, a negatív szerepet játszó támadót pedig fekete kalapos szereplőként jelenítettük meg. Az ábrán láthatók továbbá az előzőekben bevezetett fontos fogalmak, úgymint a kompromittálódás, a támadás, a sérülékenység és a biztonsági ellenintézkedés, valamint a közöttük fennálló kapcsolatok. Érdemes ezt az ábrát, mint általános modellt, mindig a fejünkben tartani.



1. ábra: Az IT-biztonság főszereplői és a közöttük fennálló alapkonfliktus.

1.2 A kompromittálódás fogalma

Ahogy korábban említettük, egy rendszert akkor tekinthetünk kompromittáltnak, ha a tervező/fejlesztő/üzemeltető által nem kívánt állapotba került. Ez egy kicsit pontatlan meghatározás, amit célszerű finomítani. Az IT-biztonság kontextusában nem kívánt állapotnak azt az állapotot tekintjük, amelyben a rendszer valamilyen biztonsági követelménye sérül, azaz kielégítetlenné válik. A kompromittálódás fogalma tehát szorosan összefügg a rendszertervező/-fejlesztő/-üzemeltető által meghatározott biztonsági követelményekkel, amelyeket a rendszernek minden körülmények között ki kellene elégítenie.

1.2.1 Alapvető biztonsági követelmények

Az IT-rendszerek esetében alapvetőnek tekintett biztonsági követelmény a rendszer erőforrásaihoz és szolgáltatásaihoz történő *hozzáférések szabályozása* (access control). Ezzel a rendszertervező/-fejlesztő/-üzemeltető általában azt szeretné elérni, hogy az erőforrásokhoz és szolgáltatásokhoz csak olyan entitások férhessenek hozzá, akiknek erre jogosultságuk van, és ezek az entitások az erőforrásokat és szolgáltatásokat csak olyan módon használhassák, amire a jogosultságuk felhatalmazza őket.

A hozzáférés-szabályozás tipikus példája az, ahogy egy számítógép operációs rendszere a fájlrendszerhez történő hozzáféréseket szabályozza. Ebben az esetben a fájlok és a fájlokat tartalmazó mappák erőforrások, amelyeket különböző módokon lehet használni. Az adatfájlokat például lehet olvasni és írni, a programfájlokat pedig lehet futtatni. A mappákat lehet böngészni, a mappákba fájlokat lehet elhelyezni, illetve a mappákból fájlokat lehet kitörölni. Az operációs rendszer felügyeli, hogy melyik felhasználó melyik mappához és fájlhoz férhet hozzá, és milyen módon használhatja azokat.

A hozzáférés-szabályozással szorosan összefügg a rendszert használó entitások megbízható azonosításának követelménye. Erre legtöbbször azért van szükség, mert a hozzáférés-szabályozás során az erőforrásokhoz és szolgáltatásokhoz történő hozzáférések engedélyezése vagy megtagadása általában attól is függ, hogy ki kezdeményezte az adott hozzáférést. Az entitások megbízható azonosítását hitelesítésnek nevezzük.

Fontos különbséget tenni az *azonosítás* (identification) és a *hitelesítés* (authentication) között. Azonosítás alatt azt a folyamatot értjük, amely során egy entitás kiléte (azonossága) megállapításra kerül. Ez a folyamat azonban nem feltétlenül megbízható; például azonosítás során egy entitás akár másnak is kiadhatja magát, mint aki ő valójában, azaz megszemélyesíthet valaki mást. A hitelesítés megbízható azonosítást jelent, ahol a megszemélyesítés ellen védekezünk. A

hitelesítés tehát magában foglalja az azonosítást, és a folyamatot kiegészíti az állított kilét (azonosság) bizonyításával. Például egy rendszerbe történő bejelentkezés során gyakran hitelesítjük magunkat egy felhasználónév-jelszó párossal. Ilyenkor a felhasználónév azonosít minket, a jelszó ismerete pedig bizonyítja a felhasználónév megadásával állított kilétünket.

További fontos követelmény szokott lenni a rendszer erőforrásai és szolgáltatásai *rendelkezésre állásának* (availability) biztosítása. Ezalatt azt értjük, hogy a rendszer erőforrásai és szolgáltatásai mindig elérhetők kell hogy legyenek a legitim felhasználók számára, amikor nekik azokra szükségük van.

Végül az eddig felsorolt tipikus biztonsági követelményekhez hozzá szokták még venni a *számonkérhetőség* (accountability) követelményét, ami nagy vonalakban azt jelenti, hogy a rendszer üzemeltetője szeretné a rendszerben történt fontosabb eseményeket (például egy kritikus erőforráshoz történő hozzáférés-próbálkozásokat) utólag visszakereshetővé tenni. Ennek jelentősége akkor válik igazán nyilvánvalóvá, amikor az üzemeltetőnek egy sikeres támadásból eredő biztonsági incidenst kell kezelnie, és meg kell állapítania, hogy pontosan mi történt a rendszerben (például hogyan alakult ki a kompromittált állapot, milyen gyengeség tette lehetővé a támadás sikerét, a rendszer mely részei érintettek, és mekkora a keletkezett kár). A fontosabb események visszakereshetősége növeli a biztonsági incidensek kezelésének hatásosságát és hatékonyságát, és ezzel jelentősen csökkentheti az incidensek során elszenvedett károk mértékét.

Az IT-rendszerekkel kapcsolatos fő biztonsági követelményekre gyakran az AAA betűhármassal szoktak hivatkozni, amely az Authentication, Authorization és Accounting angol szavak kezdőbetűiből származó rövidítés, ahol az Authentication hitelesítést, az Authorization engedélyezést (azaz szabályozott hozzáférést), az Accounting pedig az számonkérhetőség érdekében végzett eseményrögzítést jelenti. Ebből a hármasból hiányzik az Availability, azaz a rendelkezésre állás követelménye. Tehát a szokásos AAA rövidítés nyugodtan bővíthető még egy A betűvel.

Az IT-rendszerek által kezelt (tárolt, feldolgozott, továbbított) adatok tekintetében szintén léteznek alapvető biztonsági követelmények. Ezek a *bizalmasság* (confidentiality), az *integritás* (integrity), a *hitelesség* (authenticity) és a *rendelkezésre állás* (availability), ahol - a bizalmasság azt követeli meg, hogy minden adatot csak olyan entitás tudjon megismerni (olvasni), akinek erre jogosultsága van; - az integritás azt követeli meg, hogy minden adatot csak olyan entitás tudjon módosítani (írni), akinek erre jogosultsága van; - a hitelesség azt jelenti, hogy minden adat forrása megbízhatóan azonosítható kell legyen; - és végül a rendelkezésre állás követelménye azt jelenti, hogy minden adat legyen mindig elérhető azok számára, akiknek szükséges az adathoz hozzáférniük.

Az IT-rendszerek által kezelt adatokkal kapcsolatos fő biztonsági követelményekre gyakran a CIA betűhármassal szoktak hivatkozni, ami a Confidentiality, Integrity és Availability angol szavak kezdőbetűiből származó rövidítés. Ebből a hármasból hiányzik az adat forrásának hitelesítésére vonatkozó követelmény, azaz a fent is említett Authenticity. Megjegyezzük azonban, hogy az adatintegritás és -hitelesítés nagy mértékben összefüggő követelmények, abban az értelemben, hogy a gyakorlatban egyiknek sem lenne sok értelme a másik nélkül. Így a CIA rövidítés I-jébe implicit módon beleérthetjük az adat eredetének hitelességét is.

1.2.2 Kompromittált állapot

Visszatérve a kompromittálódás fogalmára, azt mondhatjuk, hogy *egy IT-rendszer akkor kompromittált, ha olyan állapotba került, melyben valamely, a rendszer tervezője/fejlesztője/üzemeltetője által megfogalmazott biztonsági követelmény (célkitűzés) nincs kielégítve*. A fent bevezetett fő biztonsági követelményeket figyelembe véve, úgy is fogalmazhatunk, hogy egy IT-rendszer akkor kompromittálódott, ha megsérült valamely - a rendszer szolgáltatásaira és erőforrásaira vonatkozó hozzáférés-szabályozási, integritási vagy rendelkezésre állási követelmény; vagy - a rendszer által kezelt (tárolt, feldolgozott, továbbított) adatra vonatkozó bizalmassági, integritási vagy rendelkezésre állási követelmény.

Az alábbi néhány példa a kompromittálódás különböző típusait szemlélteti: - jelszó vagy üzleti titok kiszivárgása (adat bizalmasságának sérülése); - adatbázisban tárolt adatok illegitim módosítása (adat integritásának sérülése); - háttértáron tárolt adatok zsarolóvírus által történő rejtjelezése (adat rendelkezésre állásának sérülése); - illegitim belépés egy legitim felhasználó e-mail- vagy közösségimédia- (például Facebook-) fiókjába (hozzáférés-szabályozási követelmény sérülése); - malware-fertőzés (erőforrás integritásának, esetleg rendelkezésre állásának, sérülése); - kiszolgáló (szerver) elárasztása nagy mennyiségű kéréssel, ami annyira leterheli, hogy nem tud legitim kéréseket kiszolgálni (szolgáltatás rendelkezésre állásának sérülése).

A fenti példák arra is emlékeztetnek, hogy *a kompromittálódás mindig valamilyen szándékos tevékenység következménye*. A véletlen hibákból származó nemkívánatos állapotot nem tekintjük kompromittálódásnak, hanem meghibásodásnak nevezzük. Bár mindkettő hasonló károkkal járhat, kezelésük, az ellenük való védekezés különböző módszereket igényel, ahogy azt már korábban említettük.

1.3 Támadómodellek

1.3.1 A támadók jellemzői

Az IT-rendszerek kompromittálódását előidéző szándékos tevékenységek mögött intelligens entitások állnak, akiket támadóknak nevezünk. A támadók különböző jellemzőkkel írhatók le, melyek közül a fontosabbak a motiváció, a képességek és a rendelkezésre álló erőforrások. Az alábbiakban ezeket a jellemzőket tekintjük részletesebben.

Motiváció

A motiváció a támadótevékenység általános, magas szintű célja, amely a támadót tevékenysége folytatására ösztönözi. Különböző támadókat különböző motivációk vezérelnek. Az önállóan tevékenykedő, egyéni támadók motivációja többnyire személyes jellegű, például lehet bosszúállás vagy valamilyen státusz elérése egy közösségben azáltal, hogy a támadó tevékenységével demonstrálja képességeit és merészségét. A támadó csoportok motivációja ezzel szemben nem személyes, hanem jellemzően gazdasági, társadalmi vagy politikai jellegű, azaz tevékenységüket profitszerzés vagy valamilyen társadalmi vagy politikai cél elérése érdekében végzik.

Képességek

Támadói képességek alatt általában információszerző képességeket és műszaki szaktudást értünk. Egy támadás sikere nagymértékben függ attól, hogy a támadó mit tud a megtámadni kívánt rendszerről, ezért a támadást megelőző, illetve a támadás során folytatott információszerzés mélysége nagyon fontos tényező. A támadó számára hasznos lehet bármilyen információ a rendszerről, de különösen értékesek a rendszer általános felépítésére, az elérhető szolgáltatásokra, az alkalmazott hardver- és szoftvereszközök típusára és konfigurációs beállításaira, a hálózati topológiára, az alkalmazott hálózati technológiákra, illetve az alkalmazott biztonsági mechanizmusokra vonatkozó információk. Fontos továbbá a rendszer szempontjából releváns, publikusan elérhető sérülékenységek, esetleg az azok kihasználását lehetővé tévő konkrét módszerek, az úgyenevezett exploit technikák ismerete is.

A támadói képességek másik formája a műszaki szaktudás, szakértelem, amely lehetővé teszi a támadások megtervezését és kivitelezését. A szakértelemnek több szintjét célszerű megkülönböztetni, az alapvető műszaki, informatikai ismeretektől kezdve a kifejezetten IT-biztonsággal kapcsolatos szaktudáson keresztül a támadási módszerek és eszközök alkalmazásának szintjéig, illetve azon túl, a teljesen új, korábban ismeretlen támadási módszerek és eszközök kifejlesztésének képességéig.

Erőforrások

A támadó számára rendelkezésre álló erőforrások alatt általában a táamdó anyagi erőforrásait értjük, melynek jelentőségét elsősorban azok információszerzésre és a technikai tudás mélységének növelésére való felhasználhatósága adja. Nagyobb anyagi erőforrásokkal rendelkező támadók könnyebben tudnak információt szerezni (például beépüléssel, zsarolással, technikai dokumentáció megszerzésével, megtévesztési technikák kiterjedtebb használatával, vagy akár hírszerzési módszerek alkalmazásával), és könnyebben férnek hozzá a támadáshoz szükséges műszaki tudáshoz (például szakemberek megfizetésével vagy saját kompetenciák fejlesztésével). A nagyobb anyagi erőforrások mindemellett fejlettebb támadóeszközök és -módszerek alkalmazását is lehetővé teszik (például nyilvánosan nem ismert sérülékenységek kihasználását, kriptográfiai algoritmusok feltörését).

1.3.2 Támadómodellek típusai

A fenti jellemzők alapján a támadókat az alábbi főbb támadómodellekbe (profilokba) szoktuk sorolni.

Script kiddie

Korlátozott tudással, információszerző képességekkel és anyagi erőforrásokkal rendelkező egyéni támadó. Motivációja elsősorban az önkifejezés, illetve státusz elérése egy szűkebb közösségben (például barátok körében). Célpontját nem előre megtervezett stratégia mentén választja, többnyire az a lényeges számára, hogy a célpont könnyen kompromittálható legyen. Jellemzően mások által kifejlesztett módszereket és eszközöket használ, melyeket publikus forrásokból, hackerfórumokról szerez be.

Elégedetlen munkatárs

Egyéni támadó, motivációja személyes jellegű, többnyire a bosszúállás. Veszélyesebb, mint a script kiddie, mert célpontja egy konkrét szervezet, motivációja általában átgondolt stratégia követésére ösztönzi, több információt birtokol vagy képes megszerezni, hozzáférési jogosultságokkal rendelkezhet, illetve személyes kapcsolatban állhat a többi felhasználóval. Technikai tudásának mélysége változó, szélsőséges esetben kiterjedt lehet. Ugyanakkor, anyagi erőforrásai általában korlátozottak.

Hacktivista csoport

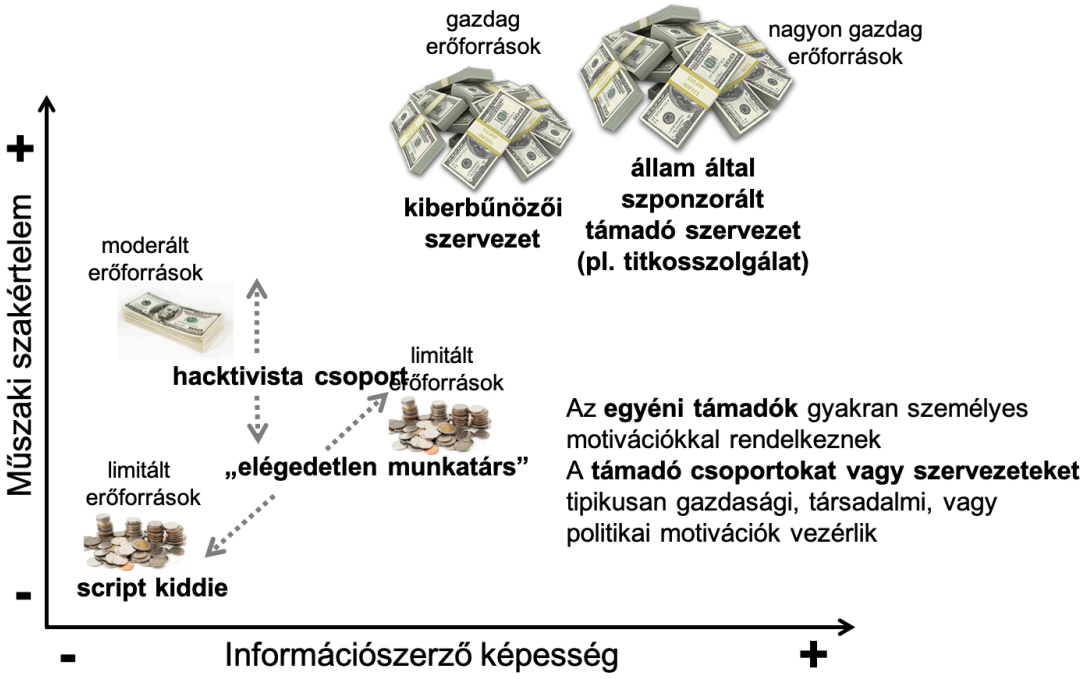
Jellemzően akciószerűen, nem hosszú távú stratégia mentén működő, laza szerveződésű támadó csoport. Motivációja tipikusan valamilyen társadalmi vagy politikai ideológia védelme, azzal kapcsolatos üzenet közvetítése, ez határozza meg a támadások célpontját és célját. Általában moderált anyagi erőforrásokkal rendelkezik, információszerző képessége korlátozott, jellemzően technikai eszközökkel, a támadás kivitelezése közben próbál több információt gyűjteni, hozzáféréseket szerezni. Technikai tudását tagjainak tudása határozza meg, így az széles skálán mozoghat: jellemzően van néhány magas képzettségű, fejlett műszaki tudással rendelkező tag, de a csoport nagy része script kiddie szinten mozog. A hacktivista csoport tipikus példája az Anonymous hackercsoport.

Kiberbűnözői szervezet

Motivációja az anyagi haszonszerzés, amelynek érdekében, átgondolt stratégiai célok mentén, nagyszabású, térben és időben kiterjedt támadó kampányokat hajt végre. A támadások célja többnyire személyes adatok, jogosultságok gyűjtése, hozzáférések ellehetetlenítése zsarolási céllal, illetve számítógépek kompromittálása és távolról irányítható botnetekbe szervezése. Az információk és a botnet által biztosított támadói potenciál közvetlenül felhasználható, de akár értékesíthető is különböző támadói fórumokon keresztül. A sikeres kiberbűnözői szervezetek jelentős anyagi erőforrásokkal és ennek köszönhetően számottevő információszerző képességgel és fejlett műszaki szaktudással rendelkeznek. Tipikus példái: Wizard Spider, Lapsus$, DarkSide.

Állam által szponzorált támadó szervezet

Motivációját, stratégia céljait és célpontjait a támogató állam politikai céljai határozzák meg. Jellemzően kémkedést folytat, szabotázsakciókat hajt végre, illetve katonai akciókat támogat. Erősen motivált, világos stratégiai célokkal rendelkezik, és tudatosan választ célpontot. Szervezett és erőforrásokban nagyon gazdag, emellett hagyományos hírszerzői módszerekre és tevékenységekre is támaszkodhat. Ez lehetővé teszi információszerző képességének mélyítését, komplex, térben és időben nagy kiterjedésű támadások végrehajtását. Technikai tudása mély, anyagi erőforrásai komplex kutatási és képzési programok végrehajtását is biztosítják. Jellemzője a kifinomult és fejlett, nemritkán mások által nem ismert támadási módszerek és eszközök alkalmazása. Tipikus példái: Comment Crew (APT1), Cozy Bear (APT29), NSA TAO.



2. ábra: Tipikus támadómodellek szemléltetése.

A 2. ábra a tipikus támadómodellek tulajdonságait és egymáshoz való viszonyukat próbálja szemléletesen bemutatni. Az ábrán a támadómodelleket az információszerző képesség és a műszaki szaktudás mélysége által kifeszített térben ábrázoltuk, illetve a modellekhez rendelt pénzkupacokkal szemléltettük a rendelkezésre álló anyagi erőforrások nagyságát. A leggyengébb támadómodell a script kiddie, amely az ábra bal alsó sarkában helyezkedik el, a legerősebb támadómodellek pedig a kiberbűnözői szervezetek és az állam által szponzorált támadó csoportok, ezek a jobb felső sarokban találhatók. A leggyengébb és a legerősebb modellek között középen találjuk az elégedetlen munkatársat és a hacktivista csoportot. Utóbbiaknál szaggatott nyilakkal szemléltettük a képességek változó jellegét.

Egy átlagos felhasználó vagy szervezet számára a legerősebb támadómodell, amelyre jellemzően számítania kell, a kiberbűnözői szervezet. A kiberbűnözés mára világméretű problémává vált. Kiberbűnözői szervezetek százai működnek illegálisan egy árnyék-ökoszisztémában, ahol a szereplők jól meghatározott feladatok ellátására specializálódtak, egymásnak termékeket állítanak elő, és szolgáltatásokat nyújtanak, melyeket különböző, jellemzően illegális fórumokon, feketepiacokon

kínálnak egymásnak, és ezekért tipikusan kriptovalutában fizetnek. Egyes szereplők például arra specializálódtak, hogy sokak által használt operációs rendszerekben és alkalmazásokban új biztonsági réseket fedezzenek fel. Ezeket a sérülékenységeket nem ők maguk használják ki, hanem a feketepiacon értékesítik más szereplőknek. Más csoportok kártékony programokat készítenek, amelyeket szintén a feketepiacon adnak el. Megint más szereplők a megvásárolt vagy szolgáltatásként igénybe vett kártékony programokkal számítógépek ezreit próbálják megfertőzni, és az így kompromittált gépekből botnet infrastruktúrát hoznak létre, melyet bérbe adnak más szereplőknek. A bérelt infrastruktúrát és megvásárolt szolgáltatásokat végül valaki konkrét támadásokhoz használja fel: például spam- vagy adathalász levelek millióit küldi ki, hamis termékeket árul egy leállíthatatlan (bullet-proof) webshopon keresztül, vagy kiszemelt rendszereket próbál elérhetetlenné tenni az interneten DDoS-támadást generálva.

Kormányzati szervezeteknek, létfontosságú infrastruktúrák üzemeltetőinek és fontos, vezető pozíciókat betöltő magánszemélyeknek nemcsak a kiberbűnözői csoportokkal kell számolniuk, hanem az idegen államok által támogatott támadókkal is. Ezek a szervezetek rendkívül fejlett képességekkel és jelentős anyagi erőforrással rendelkeznek. Míg a kiberbűnözők kampányai sok, többnyire véletlenszerűen kiválasztott áldozatot érintenek, az államilag szponzorált támadások célzottak: egy konkrét szervezetre vagy személyre irányulnak. Ezek a támadások testre szabottak, ezért nagyobb valószínűséggel sikeresek, kevesebb nyomot hagynak, és így hosszabb ideig rejtve maradhatnak. Az angol nyelvű szakirodalomban az ilyen állami hátterű támadókat *Advanced Persistent Threat* (röviden: APT) néven említik, amely fejlett, tartós fenyegetést jelent.

1.4 Támadások

A támadás az a tevékenység vagy folyamat, amely során a támadó a rendszert, annak szolgáltatásait vagy adatait kompromittálni próbálja. A támadás általában egy komplex folyamat, amely magában foglalja az előkészítő, felderítő lépéseket, a rendszer potenciális sérülékenységeinek elemzését, a sérülékenységek kihasználására alkalmas támadási módszerek és eszközök azonosítását, adott esetben új módszerek és eszközök kifejlesztését, majd az eszközök bevetését és használatát a támadás céljának elérése érdekében. Egy támadás például magában foglalhatja egy alkalmas malware beszerzését és konfigurációját, a malware célba juttatását, például egy phishing e-mail segítségével, majd a malware által megfertőzött számítógép távvezérlését.

Számos támadási módszer és eszköz létezik. Ezeknek egy nyilvánosan elérhető és kereshető gyűjteménye a CAPEC (Common Attack Pattern Enumeration and Classification), amelyet a MITRE nevű szervezet tart fenn. A CAPEC részletes mintagyűjteménye hasznos erőforrás a kiberbiztonsági elemzők, fejlesztők, tesztelők és oktatók számára egyaránt. Különösen jól alkalmazható az IT-rendszerek fenyegetettségeinek és kockázatainak elemzésében – ezt angolul threat analysis and risk assessmentnek hívnak (röviden: TARA-nak) nevezik. A TARA alapvető eszköz az IT-rendszerek kibertámadások elleni védelmének kialakításában.

1.4.1 Támadási minták

Az alábbiakban a teljesség igénye nélkül néhány magas szintű támadási mintát mutatunk be.

Hálózati behatolás

A mai IT-rendszerek ritkán működnek izolált környezetben, jellemzően hálózatok részei, és az internet felől is elérhetők. Hálózati behatolásról akkor beszélünk, amikor a támadó ezeket a kapcsolatokat kihasználva, távolról kompromittálja a rendszert (például kívülről elérhető hálózati szolgáltatásban felfedezett hiba kihasználásával átveszi egy belső komponens felett az irányítást, vagy a távoli hozzáférés lehetőségét kihasználva, hitelesítő információkat megszerezve, legitim felhasználó vagy szolgáltatás nevében távolról belép).

Kártékony programok használata

A támadó több szinten alkalmazhat kártékony programokat, azaz malware-t. Az első behatolás alkalmával általában a rendszerben eleve meglévő távoli hozzáférési lehetőséget aktiváló malware telepítése a jellemző, majd ennek segítségével a támadó újabb és komplexebb modulokat juttathat a rendszerbe. Ezzel a módszerrel a támadó több jogosultságra tehet szert, biztosíthatja a folyamatos jelenlétet (perzisztencia), és kikapcsolhat bizonyos védelmi funkciókat.

A modern malware-ek moduláris felépítésűek, távolról vezérelhetők, elemeik önállóan futtathatók, már futó folyamatokba vagy az operációs rendszerbe is beépülhetnek. A távvezérléshez szükséges kommunikáció általában rejtjelezett és fedő forgalomba ágyazott, melyet a tűzfalak átengednek. A malware-nek önálló terjedést megvalósító funkciói is lehetnek, de jellemzően használt disztribúciós módszerek az e-mail, a megtévesztő weboldalak és a fertőzött adathordozók is.

Kriptográfiai algoritmusok feltörése

Az adatok átvitel vagy tárolás során történő védelmének alapvető eszközei a kriptográfiai algoritmusok (például rejtjelezés, digitális aláírás), melyek az adatok lehallgatás és módosítás elleni védelmére, valamint hitelességének ellenőrzésére használhatók. Bár a kriptográfiai algoritmusok többsége elég erős és nehezen törhető fel, mélyebb tudással rendelkező

támadók (például APT) esetében ezt a lehetőséget sem lehet kizárni. Egy kriptográfiai algoritmus feltörése azt jelenti, hogy a támadó talál egy olyan módszert, amellyel szisztematikusan tud rejtjelezett adatot dekódolni vagy integritásvédelemmel ellátott adatot módosítani titkos kulcsok birtoklása nélkül is.

Protokoll és API-hibák kihasználása

A protokollok elleni támadások célja lehet egy résztvevő megszemélyesítése, a protokoll üzeneteinek feltörése, módosítása, visszajátszása, hamis üzenetek előállítása, egy titkos kulcs megszerzése vagy egy régebbi, már kompromittált kulcs elfogadtatása valamelyik résztvevővel. Ezeknek a céloknak az eléréséhez a támadónak általában a legitim protokollrésztvevők közé kell ékelődnie – úgynevezett Man-in-the-Middle pozícióba kerülnie –, hogy manipulálni tudja a résztvevők közötti kommunikációt. A protokollokhoz hasonlóan API-kkal is számos környezetben találkozhatunk. Esetükben a támadó általában olyan előre nem látott módon hívja meg az API függvényeit, ami végül a rendszer kompromittálódásához vezet.

Fizikai behatolás

Fizikai behatolás során a támadó átjut a rendszer vagy egyes rendszerkomponensek számára biztosított fizikai védelmi mechanizmusokon (például kijátssza a biztonsági őrt, vagy feltöri egy ajtó zárját), és így fizikai hozzáférést szerez a rendszerhez vagy a rendszer egy eleméhez. Az ilyen közvetlen fizikai hozzáférés általában erősebb, komolyabb következményekkel járó logikai támadást tesz lehetővé, mint ha a támadónak csak távoli hozzáférése lenne. Például ha a fizikailag közvetlenül elérhető rendszerelem nem kifejezetten bontásellenálló (tamper resistant), akkor a fizikai hozzáférés lehetővé teheti a rendszerelemen tárolt adatok kiolvasását vagy a futó programok módosítását.

Humán felhasználók elleni támadások

A technikai jellegű támadások mellett a humán felhasználók ellen irányuló támadások is fontosak, mert hatékonyak lehetnek. Ez annyira igaz, hogy sokan a humán felhasználókra úgy tekintenek, mint az IT-rendszerek biztonságának leggyengébb láncszemeire. Ez a tekintetben igaz, hogy hiába alkalmazunk technikailag erős biztonsági megoldásokat, ha a felhasználók nem felkészültek ezek megfelelő használatára. A social engineering olyan megtévesztéses támadás, melyben a támadó egy humán felhasználóval lép kapcsolatba (például telefonon keresztül), és a felhasználót megtévesztve kicsikar tőle valamilyen szenzitív információt, vagy ráveszi a felhasználót valamilyen kockázatos tevékenységre (például egy adott kártékony program letöltésére és telepítésére). A phishing támadás hasonló, azzal a különbséggel, hogy phishing során a támadó egy megtévesztő tartalmú e-mailt küld, és ennek segítségével veszi rá a felhasználót valamilyen kompromittáláshoz vezető lépésre.

1.4.2 Az aktív és a passzív támadások

A támadások sokfélék lehetnek, mégis két alapvető típus különíthető el: a *passzív* és az *aktív* támadások. Passzív támadás esetén a támadó nem avatkozik be a rendszer vagy protokoll működésébe, csak megfigyel. Tipikus példa erre egy kommunikációs csatorna lehallgatása. Ezzel szemben aktív támadásról beszélünk, ha a támadó aktívan beavatkozik: befolyásolja, módosítja vagy el is lehetetleníti a rendszer vagy protokoll működését. Ilyen lehet például az üzenetek módosítása, törlése vagy beszúrása egy kommunikációs csatornába, malware telepítése, adatbázisrekordok törlése, háttértár titkosítása vagy egy szerver elárasztása nagy mennyiségű forgalommal és ezzel a szerver leterhelése. Érdekes különbség, hogy a passzív támadások többnyire észrevétlenek maradnak, ezért ezeknél a megelőzés a legfontosabb. Az aktív támadásokat nehezebb megelőzni, viszont aktív természetük miatt általában észlelhetők, így itt a gyors felismerés és reagálás a kulcs.

1.5 Gyengeségek és sérülékenységek

A sikeres támadások mindig valamilyen gyengeség vagy konkrét sérülékenység kihasználására épülnek. Gyengeségek és sérülékenységek azonban nemcsak magában a rendszerben jelentkezhetnek, hanem előfordulhatnak a rendszer környezetében is. Egy IT-rendszer környezetéhez tartozik a rendszert befogadó fizikai környezet, valamint a rendszert tervező/fejlesztő/üzemeltető szervezet és annak alkalmazottai, beszállítói. A támadás sikeréhez sokszor hozzájárulnak ezek hibái, gyengeségei is. A rendszerben található gyengeségek és sérülékenységek sokszor műszaki jellegűek. Ezzel ellentétben, a rendszer környezetében tipikusan nem műszaki jellegű gyengeségekkel és sérülékenységekkel találkozhatunk.

1.5.1 A sérülékenységek főbb típusai

Logikai gyengeségek, sérülékenységek

Logikai gyengeségnek, sérülékenységnek nevezzük azokat a rendszerben található műszaki jellegű hibákat, amelyek logikai szintű támadásokat tesznek lehetővé. Logikai gyengeségek és sérülékenységek előfordulhatnak tervezési és implementációs szinten a rendszert alkotó hardver- és szoftverkomponensekben, valamint a komponensek interakcióját biztosító protokollokban. Egy alkalmazásban található programozói hiba például szoftverkomponenst érintő implementációs szintű sérülékenységnek tekinthető.

Fizikai gyengeségek, sérülékenységek

Fizikai gyengeségnek, sérülékenységnek nevezzük a rendszer fizikai környezetében található olyan hibákat, melyek a rendszerhez történő fizikai szintű hozzáférést tesznek lehetővé. Ilyenek lehetnek például az egyszerűen nyitható zárak, az őrzés nélkül hagyott bejáratok, a folyosón elhelyezett, bárki által hozzáférhető hálózati eszközök és csatlakozók vagy az elektromágneses árnyékolás hiánya.

Szervezeti szintű gyengeségek, sérülékenységek

A rendszert tervező/fejlesztő/üzemeltető szervezet eljárásrendjeiben, működési és munkafolyamataiban található gyengeségek és sérülékenységek olyan procedurális hibák, amelyek kihasználása nagy mértékben segítheti a rendszer elleni fizikai vagy logikai támadásokat. Ilyen hiba lehet például, ha az üzemeltető szervezet nem írja elő és nem kényszeríti ki az alapértelmezett (default) jelszavak lecserélését, vagy ha egyetlen rendszergazda hozzáférhet minden kritikus alrendszerhez.

Személyzeti szintű gyengeségek, sérülékenységek

A rendszert tervező/fejlesztő/üzemeltető szervezet alkalmazottjaival kapcsolatos személyzeti szintű hibák kihasználása ugyancsak segítheti a rendszer elleni fizikai és logikai támadásokat. Ilyen típusú hiba például az üzemeltető személyzet anyagi megbecsülésének alacsony szintje vagy egyéb, a személyzet elégedetlenségét növelő hiányosság, amely csökkenti a szervezet iránti lojalitást, zsarolhatóvá teszi az alkalmazottakat. Szintén ebbe a kategóriába tartozó hiba, ha bármely szervezet elmulasztja a biztonságtudatosság kialakítását és szinten tartását.

A biztonságot gyakran egy lánchoz hasonlítják: ahogy egy lánc erősségét is a leggyengébb láncszem erőssége határozza meg, úgy az IT-rendszer biztonságát is a legkönnyebben kihasználható gyengeségek befolyásolják. Ezek a sérülékenységek sokszor nem műszaki jellegűek (azaz logikai vagy fizikai gyengeségek), hanem szervezeti vagy személyzeti szintűek. A leggyengébb láncszemet sokszor a felhasználók vagy a rendszert működtető humán személyzet biztonságtudatosságának, lojalitásának alacsony szintje jelenti. Ezt mindig szem előtt kell tartani, amikor egy IT-rendszer biztonságáról beszélünk.

1.5.2 A logikai gyengeségek, sérülékenységek okai és kezelése

A logikai gyengeségek és sérülékenységek létezésével folyamatosan számolni kell. Ennek elsődleges oka az, hogy az IT-rendszerek felépítése többnyire komplex, nehezen átlátható, és sok hibalehetőséget rejt magában. Egy gyakorlatban használt rendszer komplexitásának szintje általában nem teszi lehetővé a kimerítő hibakeresést (tesztelést) vagy a hibamentesség formális úton történő bizonyítását. Ráadásul a technológia fejlődésével a rendszerek még komplexebbé válása figyelhető meg, tehát a jövőben sem várható a helyzet jelentős javulása.

Bár valamennyi gyengeség és sérülékenység azonosítása és megszüntetése lehetetlen feladatnak tűnik, azért sokan törekszenek arra, hogy minél több hibát, biztonsági rést megtaláljanak mindenféle rendszerben. Ha valaki felfedez egy korábban ismeretlen sérülékenységet egy adott rendszerben vagy rendszerelemben, akkor az számára ismertté válik. Sok esetben az így felfedezett sérülékenységek, egy kontrollált folyamat mentén, idővel publikusan is ismertté válnak. Ezt a folyamatot *felelősségteljes közzétételnek* (responsible disclosure) nevezzük, és a lényege az, hogy a sérülékenység felfedezője értesíti az érintett hardver- vagy szoftverkomponens gyártóját vagy fejlesztőjét vagy az érintett rendszer üzemeltetőjét, és időt biztosít a sérülékenység javítására, mielőtt nyilvánosságra hozza azt.

A nyilvánosságra hozatal célja kettős: egyrészt kényszeríti a gyártót/fejlesztőt/üzemeltetőt, hogy javítsa a hibát és elimináljа a sérülékenységet (máskülönben a gyártó/fejlesztő/üzemeltető esetleg nem venné kellően komolyan a problémát), másrészt lehetővé teszi minden, a sérülékenység által érintett entitás számára, hogy tudomást szerezzen a sérülékenység létezéséről, és megszüntesse azt saját rendszerében, vagy a javítás alkalmazásával, vagy más módon. Ugyanakkor, a nyilvánosságra hozatal a potenciális támadóknak is lehetőséget ad arra, hogy tudomást szerezzenek a sérülékenységről, és ez ellentmondásosnak tűnhet. Szerencsére a felelősségteljes közzététel biztosítja, hogy mire a sérülékenység publikusan ismertté válik, addigra már rendelkezésre áll a javítása. Így összességében az ilyen módon történő a nyilvánosságra hozatalnak több haszna van, mint amekkora potenciális kárt okozhat.

A publikusan ismert sérülékenységeket a CVE (Common Vulnerabilities and Exposures) adatbázis tartalmazza, amely egy mindenki számára elérhető erőforrás az interneten. Az adatbázisban található sérülékenységek egyedi azonosítóval (CVE ID) rendelkeznek, és minden rekord tartalmazza az adott sérülékenység leírását, az érintett konkrét rendszerelemek (például hardvereszközök, szoftververziók) felsorolását, valamint a sérülékenység súlyosságának (severity) becslését.

Míg a CVE adatbázis konkrét termékek konkrét sérülékenységeit, biztonsági hibáit tartalmazza, addig egy másik nyilvánosan elérhető adatbázis, a CWE (Common Weakness Enumeration) az ismert biztonsági gyengeségek általános, konkrét termékektől független leírásainak, a MITRE által kezelt gyűjteménye. A CWE-rekordok tehát magasabb szintű leírásokat tartalmaznak, melyekre akár sérülékenység-archetípusként is tekinthetünk. Ugyanakkor a CWE-rekordok hivatkozhatnak CVE-rekordokra mint egy adott gyengeség konkrét gyakorlati előfordulási példájára. Hasonlóan, a CVE-rekordokban is lehet hivatkozás egy adott sérülékenység szempontjából releváns CWE-rekordokra.

A fejlettebb technikai tudással rendelkező támadók folyamatosan keresik a nyilvánosan még nem ismert, úgynevezett *nulladik napos* (zero-day) sérülékenységeket. A támadó számára nagy előnyt jelent, ha ilyet talál valamilyen széles körben használt rendszerkomponensben, például egy elterjedt operációs rendszerben vagy egy sokak által használt alkalmazásban, mivel ez a

mások számára még ismeretlen sérülékenység nagyszámú rendszer kompromittálását könnyítheti meg. Értelemszerűen a rendszer tervezője/fejlesztője/üzemeltetője sincs még tudatában az adott nulladik napos sérülékenység létezésének, ezért várhatóan nem készítette fel a rendszert az azt kihasználó támadásokra, és így a támadó nagy valószínűséggel sikeresen és többnyire észrevétlenül tudja kompromittálni a rendszert e sérülékenység kihasználásával.

Egy támadó nemcsak maga kereshet és találhat új, eddig ismeretlen sérülékenységet, hanem vásárolhat is ilyet a "piacon" olyan szereplőktől, akik új sérülékenységek keresésére specializálódtak. Ezek a szereplők nem követik a felelősségteljes közzététel folyamatot, helyette inkább eladják a felfedezett sérülékenységeket az azok iránt érdeklődő támadóknak. A zero-day sérülékenységek száma azonban limitált, és az áruk nagyon magas. Ezért jellemzően csak a jelentős anyagi erőforrásokkal rendelkező, állam által szponzorált támadó szervezetek vásárolnak zero-day sérülékenységeket, és tipikusan célzott támadásokban használják fel azokat. Ezeknél a támadásoknál fontos szempont a magas sikervalószínűség, amit a zero-day sérülékenység lehetővé tud tenni, ugyanakkor a célzott támadás lebukásának valószínűsége kicsi, ami pedig hozzájárul a felhasznált sérülékenység zero-day jellegének megőrzéséhez.

1.6 Biztonsági mechanizmusok, ellenintézkedések

Ahogy a gyengeségek és sérülékenységek is lehetnek logikai és fizikai jellegűek, valamint jelentkezhetnek az IT-rendszert tervező/fejlesztő/üzemeltető szervezet és személyzet szintjén, úgy a rendszer és az adatok védelmét célzó biztonsági kontrollok is lehetnek logikai, fizikai, szervezeti és személyzeti szinten megvalósított mechanizmusok.

Logikai szintű védelem

A logikai szintű megoldások körébe tartoznak az IT-rendszert alkotó számítógépek és az azokat összekötő hálózatok biztonsági mechanizmusai, valamint az adatok védelmét szolgáló kriptográfiai sémák. Példaként említhetők az alábbiak:

- a hálózati peremvédelmet ellátó tűzfalak;
- a mélységi védelmet megvalósító hálózati behatolás detektáló rendszerek;
- a számítógépeken és hálózati eszközökön futó antivírus megoldások;
- az operációs rendszer szintjén megvalósított felhasználóhitelesítés és hozzáférés-szabályozás a fájlokhoz és a memóriához;
- a biztonság szempontjából releváns események naplózása és a naplóelemző eszközök;
- az adatok rejtjelezését, integritásvédelmét és hitelesítését megvalósító kriptográfiai primitívek;
- valamint az ezekből felépített, a kommunikációs kapcsolatok védelmét ellátó komplexebb kriptográfiai protokollok.

Szervezeti szintű védelem

Szervezeti szintű védelem alatt elsősorban a szervezet által alkalmazott, biztonsági célú rendszabályok és eljárásrendek együttesét, illetve az ezek betartását, megvalósítását lehetővé tevő szervezeti kialakítást értjük. Ide tartozik például egy IT-biztonsági felelős kijelölése, kockázatelemzés végrehajtása, incidenskezelésért felelős csapat létrehozása és felkészítése, a szervezet biztonsági politikájának definiálása, az azt megvalósító szabályzatok és eljárások megalkotása, valamint a biztonságtudatosságot növelő rendszeres képzések megszervezése.

Fizikai szintű védelem

A fizikai szintű védelem eszközei közé tartoznak például a falak, zárak, biztonsági őrök és kamerák, illetve a bontásellenálló eszközök fizikai védelmi megoldásai. A szervezeti szinten jelennek meg a biztonsági feladatokhoz rendelt felelősök és szervezeti egységek, valamint ezek hatáskörét és operatív működését leíró szabályzatok és eljárásrendek.

Személyzeti szintű védelem

Végül a személyzeti szinten is említhető pár fontos példa a biztonságot szolgáló mechanizmusokra, úgymint a biztonságtudatosság növelése képzések útján, valamint a személyzet elégedettségének és lojalitásának növelése a megfelelő munkakörnyezet és vonzó anyagi feltételek kialakításával.

1.6.1 A biztonsági mechanizmusok célja

A biztonsági mechanizmusok a rendszertervező/-fejlesztő/-üzemeltető eszközei a támadások elleni védekezésre. Természetesen a legjobb az lenne, ha a sikeres támadásokat mindig el tudnánk kerülni, ezért sok biztonsági mechanizmus célja a *megelőzés*. Képzeljünk el például egy tűzfalat, amely a belső hálózatunk és az internet közötti forgalmat szűri, és ezzel próbálja megelőzni, hogy támadó jellegű forgalom érkezzen belső hálózatunkba, vagy hogy adatainkat ellopják és feltöltsék valamilyen külső szerverre. Az adatok rejtjelezése egy másik megelőző jellegű biztonsági mechanizmus, amely praktikusan lehetetlenné teszi az érzékeny adatokhoz történő hozzáférést a támadók számára.

Sajnos nem minden támadást lehet megelőzni, vagy túl komplikált és költséges lenne minden esetben kizárólag a megelőzésre törekedni. Ezért számos biztonsági mechanizmus célja a támadások (gyors) *észlelése*, amely lehetővé teszi, hogy a támadásra valamilyen hatásos ellenlépést hajtsunk végre. A legtöbb detekciós mechanizmus arra törekszik, hogy a támadást

minél előbb, még a rendszer vagy az adatok teljes kompromittálódása előtt észlelje, így van esély arra, hogy az ellenlépések a támadást ellehetetlenítsék vagy legalább a támadás kiterjedését behatárolják, hatását korlátozzák, és ezzel a kárt minimalizálják.

Észlelést biztosító védelmi mechanizmus például egy hálózati behatolás detektáló rendszer vagy egy hoston futó antivírus szoftver. Mindkettő működhet ismert támadó mintázatok (például egy ismert, korábban már látott malware-minta) vagy a hálózati forgalomban, illetve a számítógépen mutatkozó anomáliák (például szokatlan adatforgalom egy ismeretlen külső szerver felé) észlelése útján. Az észlelést általában riasztás követi, ami végül az ellenlépéseket triggereli. Utóbbi lehet teljesen automatizált folyamat is (például egy vírusnak észlelt fájl karanténba helyezése), vagy a riasztás befuthat egy rendszerfelügyeletet ellátó személyhez vagy szervezeti egységhez, amely a riasztás hátterét kivizsgálja, és a megfelelő ellenlépések megtételét elindítja. Nagyobb rendszerek esetében általában egy dedikált szervezeti egység működteti az észlelést biztosító biztonsági mechanizmusokat, illetve gyűjti és kezeli a riasztásokat. Ezt biztonsági műveleti központnak, angolul Security Operation Centre-nek, vagy röviden SOC-nak nevezik.

Végül fontos megemlíteni, hogy bár az információbiztonság célja annak elérése, hogy rendszerünk és adataink ne kerüljenek kompromittált állapotba, a gyakorlatban nincsen tökéletes, 100%-os biztonság, azaz fel kell készülnünk arra is, hogy minden erőfeszítés és az alkalmazott védelmi mechanizmusok ellenére, egy-egy támadás bizony lehet sikeres. Ekkor nagyon fontos, hogy a keletkező helyzetet, amit *biztonsági incidensnek* hívunk, hatásosan tudjuk kezelni, és minimalizáljuk az elszenvedett kárt. Ez az incidensmenedzsment feladata, amely fontos témakör az IT-biztonságon belül.

1.7 Az információbiztonság kockázatalapú megközelítése

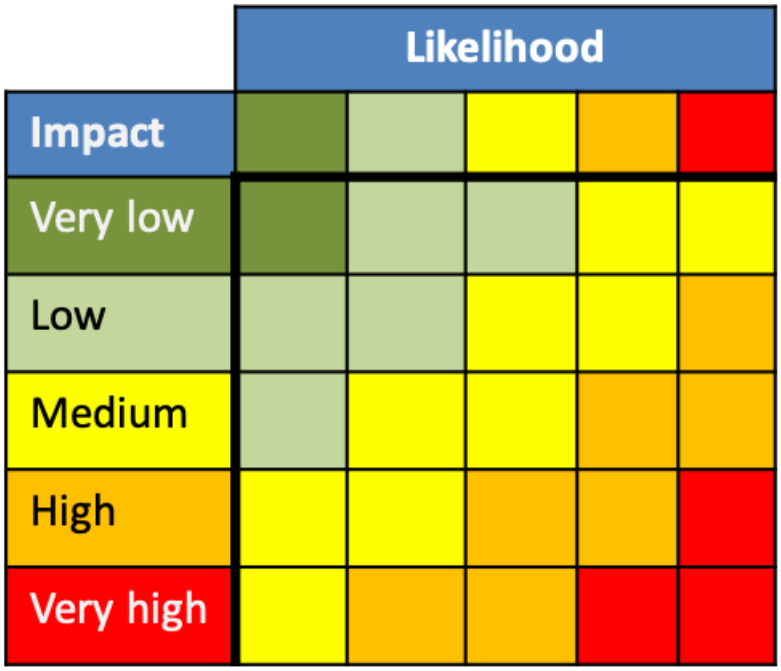
Az információbiztonság célja az IT-rendszerek és az általuk kezelt adatok szándékos támadások elleni védelme, azaz a kompromittálódás elkerülése. E cél érdekében biztonsági mechanizmusokat alkalmazunk, amelyek a támadások megelőzését vagy gyors észlelését teszik lehetővé, továbbá észlelés esetén elősegítik a hatásos válaszlépések megtételét, melyekkel az észlelt támadás ellehetetleníthető vagy hatása minimalizálható.

Minden lehetséges támadás ellen azonban nem tudunk védekezni. Egyrészt a rendszerek komplexitásából fakadóan a lehetséges támadások száma olyan nagy, hogy mindet azonosítani és mindre felkészülni lehetetlen vállalkozás lenne. Másrészt, még ha ismernénk is minden lehetséges támadást, mindegyik ellen védekezni túl költséges lenne. A gyakorlatban a biztonságra költhető költségvetés nem végtelen, és mindig az adott anyagi keretek között kell megoldani rendszereink és adataink védelmét.

Ez azt jelenti, hogy valahogy rangsorolnunk kell a lehetséges támadásokat, és a fontosabbakkal kell először foglalkoznunk, majd ha azok ellen már bevezettük a megfelelő biztonsági mechanizmusokat, és anyagi kereteink még engedik, akkor léphetünk tovább, és foglalkozhatunk a kevésbé fontos támadásokkal. De mitől lesz egy lehetséges támadás fontosabb, a rangsorban előrébb álló, mint egy másik? Ennek megállapítására használhatjuk a *kockázat* fogalmát.

Kockázata egy fenyegetettségnek lehet, ahol *fenyegetettség* (threat) alatt egy konkrét célra fókuszáló és egy adott támadó típus (modell) által végrehajtható lehetséges támadást értünk. *Egy fenyegetettség kockázata a fenyegetettség realizálódásából származó várható veszteség.*

Elméletben a kockázatot úgy számolhatjuk ki, hogy a fenyegetettség realizálódásának valószínűségét megszorozzuk a realizálódás esetén elszenvedett veszteség (kár) mértékével. A gyakorlatban sokszor sem a realizálódás valószínűségét, sem az elszenvedett veszteség mértékét nem tudjuk pontosan meghatározni. Ezért konkrét számok helyett jellemzően mindkettőt csak egy kvalitatív skála megfelelő értékeivel jellemezzük. Például egy fenyegetettség realizálódásának valószínűségére mondhatjuk, hogy “alacsony”, “közepes” vagy “magas”. Persze használhatunk ennél finomabb skálát is. Ilyenkor a kockázatbecslését egy táblázat segítségével végezzük, melyben definiálva van, hogy adott kvalitatív valószínűséghez és veszteségszinthez milyen kvalitatív kockázat tartozik. Egy ilyen táblázatot szemléltet a 3. ábra. Az így nyert kvalitatív kockázat nem egy pontos becslés, ugyanakkor a fenyegetettségek rangsorolására, priorizálására lehetőséget ad. Szükség esetén – például, ha egy kockázati szinthez túl sok azonosított fenyegetettség tartozik – a kvalitatív skála finomítható.



3. ábra: Kvalitatív kockázat számítását segítő táblázat.

1.7.1 A kockázatmenedzsment folyamata

Az információbiztonságot sokan a fenti módon definiált kockázat menedzsmentjének tekintik. Ezt a hozzáállást nevezzük az információbiztonság kockázatalapú megközelítésének. A kockázatmenedzsmentet egy jellemzően ciklikus folyamatként szokták leírni, melyben a következő lépések sorozata ismétlődik:

1. Azonosítás (identification)
2. Értékelés (assessment)
3. Kezelés (treatment)
4. Felügyelet, figyelemmel kísérés (monitoring)

Azonosítás

A kockázatmenedzsment első lépéseként a rendszertervezőnek/-fejlesztőnek/-üzemeltetőnek azonosítania kell a rendszer értéket képviselő elemeit (assets). Értéket képviselhet minden, aminek kompromittálódása veszteséget okoz. Ilyen módon értékek lehetnek a rendszer szolgáltatásai, kritikus hardver- és szoftverkomponensei, erőforrásai, a rendszerben tárolt, feldolgozott és továbbított adatok vagy akár a rendszert tervező/fejlesztő/üzemeltető személyzet.

Ahogy korábban említettük, a fenyegetettség egy konkrét támadási célra (azaz értéket képviselő elemre) fókuszáló és egy adott támadó típus (modell) által végrehajtható lehetséges támadás. Ezért a kockázatmenedzsment első fázisában az értéket képviselő elemek azonosítása mellett fel kell térképezni azt is, hogy milyen támadó típusokkal állhatunk szemben, és milyen lehetséges támadásokat hajthatnak ezek végre az azonosított értékeink ellen. Ezt fenyegetettségazonosításnak (threat identification) hívjuk.

Értékelés

A folyamat második, kockázatértékelés fázisában a rendszertervezőnek/-fejlesztőnek/-üzemeltetőnek meg kell becsülnie az azonosított fenyegetettségek realizálódásának valószínűségét és a realizálódás esetén bekövetkező veszteség mértékét, majd ebből meg kell határoznia a fenyegetettségek kockázatát. Ehhez a korábban már említett kvalitatív szintek (például “alacsony”, “közepes”, “magas”) és a 3. ábrán illusztrált kockázatszámító módszer is használható. A második fázis kimenete az azonosított fenyegetettségek kockázataik alapján felállított rangsora.

Kezelés

A folyamat harmadik, kockázatkezelés fázisában a rendszer-tervező/-fejlesztő/-üzemeltető azonosítja a fenyegetettségek kezelésére alkalmazható, azaz a fenyegetettségek realizálódásának elkerülését célzó lehetséges biztonsági mechanizmusokat, ellenintézkedéseket és azok költségét. Ezután a rendszertervező/-fejlesztő/-üzemeltető a lehetőségek közül megpróbálja kiválasztani az alkalmazható biztonsági mechanizmusok egy olyan részhalmazát, amellyel a rangsor tetejéről indulva a lehető legtöbb fenyegetettséget kezelni tudja a rendelkezésre álló anyagi erőforrások mellett. Lehetséges az is, hogy a rendszertervező/-fejlesztő/-üzemeltető előre meghatároz egy kockázati szintet, amit még el tud viselni, és igyekszik úgy választani és bevezetni a biztonsági mechanizmusokat, hogy azokkal minden ennél nagyobb kockázatú fenyegetettséget

kezelni tudjon az adott anyagi keretek mellett. Fontos megérteni azt, hogy a fenyegetettségek kezelése azt jelenti, hogy a biztonsági mechanizmusok bevezetése által kockázatukat csökkentjük, egy elfogadható szint alá hozzuk, de általában nem csökkentjük teljesen nullára!

Felügyelet

A folyamat negyedik fázisa arról szól, hogy a rendszer üzemeltetése során folyamatosan figyelemmel kísérjük az eseményeket, és elemezzük az esetlegesen bekövetkező biztonsági incidenseket. Ennek a rendszermonitorozásnak és incidenselemzésnek az a célja, hogy megállapítsuk, hogy korábban helyesen azonosítottuk-e az értékeinket és azok fenyegetettségeit, helyesen becsültük-e meg a kockázatokat, és elég hatásos biztonsági mechanizmusokat vezettünk-e be a rendszerünkbe. Ha valahol hiányosságot tapasztalunk, akkor a kockázatmenedzsment folyamatot újra kell kezdeni és annak lépéseit újra végrehajtva, immár körültekintőbben kell rendszerünk védelmét kialakítani.

Különös figyelmet érdemelnek azok az incidensek, melyek nagy veszteséget okozó, alacsony valószínűségűnek gondolt fenyegetettségek realizálódásából erednek. Ilyen esetekben az incidens elemzésének arra a kérdésre kell választ adnia, hogy vajon korábban rosszul becsültük-e meg a fenyegetettség realizálódásának valószínűségét, vagy csupán egy valóban alacsony valószínűségű esemény következett be. Ha becslésünk volt helytelen, akkor újra végre kell hajtani a kockázatmenedzsment folyamatot, és óvatosabb becsléseket kell adnunk a valószínűségekre.

◄ Commitment értékek az opcionális pontokhoz

Ugrás...

VirtualBox Image (x86) ►

Impresszum | Copyright © 2018 BME Villamosmérnöki és Informatikai Kar
1117 Budapest, Magyar tudósok körútja 2. | +36 1 463 3581 | moodle@vik.bme.hu